CONSULTANT GUIDE

FileMaker Security Audit

What the audit is, what you need before you start, and every step from opening the repo to handing the client their report.

Version 0.1 · October 2026 · Not yet tried against a live server; report anything that shows Not checked unexpectedly.

Contents

1. What we do
2. Ground rules
3. What you need
4. Running an audit
5. The OS script in detail
6. Exporting the accounts XML
7. When something goes wrong
8. Close-out checklist

What we do

We give the client a dated, best-practice review of their FileMaker Server and the files it hosts. The audit catches the drift we see a year after handoff: privileges opened up to get something built, and everyone working on full-access accounts. The client gets a report that says what passes, what doesn't, and how to fix it. Fixing it is their call and their work, unless they hire us to help.

Server checklist

FileMaker Server settings through the Admin API and OttoFMS: version, certificate, encryption, web publishing, backups, schedules.

OS checklist

Listening ports, firewall, OS version and patching, local admins, disk encryption and antivirus, from one pasted script.

File audits

Accounts, privilege sets and extended privileges for each hosted file, from an accounts-only XML export.

What it is **not**: ongoing monitoring, log review, password testing, or any testing from outside the client's network. The report says so in plain words.

Ground rules

Always

- Type passwords only at the local login prompt in your own terminal.
- Keep client data inside `audits/`, which git ignores.
- Run the OS script as given, read-only, inside your normal remote desktop session.
- Let the rules decide pass or fail; edit only the summary paragraph.

Never

- Paste a password into Claude or Codex. If one ends up there, stop and tell the client to change it.
- Install anything on the client's server, or change a setting during the audit.
- Scan or probe the server from outside. That is a separate service with its own authorization.
- Commit anything from `audits/`, or turn off the secret-scan hook.

What you need

ITEM	FROM	USED FOR
Network reach to the server (office network or VPN)	Client	Admin API and OttoFMS over HTTPS
FMS Admin Console username and password	Client	Server checklist
Separate OttoFMS credentials, only if OttoFMS doesn't use the Admin Console login	Client	OttoFMS checks
Remote desktop access: RDP for Windows, Screen Sharing or similar for Mac, ideally as an administrator	Client	OS checklist

ITEM	FROM	USED FOR
A Full Access login per file, or the client's admin to export the XML	Client	File audits
Signed engagement letter, including the AI-processing line	RCC	Before any access
The repo, Python 3, and Claude Code or Codex on your laptop	RCC	Everything

Running an audit

Plan on about an hour per server once you have access. Everything runs from your own Mac or Windows laptop.

1 Open the repo and start the audit

You + agent

Pull the latest version, open the repo in Claude Code or Codex, and ask:

```
Run fms-audit for Example Co, server fms.example.com
```

The agent creates `audits/example-co/2026-10-30/` and asks a few questions it records for the rules: which accounts belong to developers, and which privilege sets genuinely need the Data API, OData or WebDirect.

2 Log in at the local prompt

You

In a separate terminal window, not the agent chat:

```
python -m audit login fms.example.com
```

Type the Admin Console password, and the OttoFMS credentials if asked. They go into your computer's keychain. The agent never sees them.

3 Collect server settings Agent

The agent runs the server and OttoFMS checks over HTTPS. Nothing to do on the server. If OttoFMS isn't installed, those checks are marked Not checked and the run carries on.

4 Run the OS script in your remote desktop session You

The agent copies the right script to your clipboard. Paste it into a terminal on the server, then copy the result back. Details in The OS script in detail.

5 Add the accounts XML for each file You or client

Export an accounts-only XML for each hosted file and drop it in the engagement folder. See Exporting the accounts XML. If the client does this, the agent prints instructions you can send them.

6 Build and review the report Agent, then you

The agent runs the rules and builds `report.html` and `report.pdf`. Read the whole thing. You may edit the executive summary; if a finding looks wrong, fix the input or the rule, not the report.

7 Close out You

```
python -m audit logout fms.example.com
```

Deliver the PDF, copy the engagement folder to RCC's client storage, and work through the close-out checklist.

The OS script in detail

One self-contained script, pasted into a terminal in the remote desktop session you already have. It only reads. It writes nothing to the server's disk and installs nothing. No SSH, WinRM or file transfer is needed.

Windows server (RDP)

1. On your laptop: `python -m audit os-script win`
2. In the RDP session, right-click Start, open **Terminal (Admin)** or **PowerShell** with Run as administrator.
3. Paste and press Enter.
4. When it finishes, the result block is already on the clipboard.

Mac server (Screen Sharing)

1. On your laptop: `python -m audit os-script mac`
2. In the Screen Sharing session, open **Terminal**.
3. Paste and press Return. Enter the admin password once when sudo asks.
4. When it finishes, the result block is already on the clipboard.

Back on your laptop:

```
python -m audit os-import --out audits/example-co/2026-10-30/
```

This reads your clipboard, checks the block's checksum, and saves `os.json` in the engagement folder. The result looks like this:

```
----- FMS-AUDIT OS BEGIN v1 -----
H4sIAAAAAAAAA+1YW2/bNhR+z68heiNeZ9Lwl1t0O0IeiSLEB...
sha256: 9f2c...e41a
----- FMS-AUDIT OS END -----
```

> If the clipboard doesn't come across, select everything from BEGIN to END in the server window, copy it by hand, and run `audit os-import` again.

Without admin rights

The script still runs and marks what it couldn't read as Not checked, with the reason. That's acceptable, but say so in the summary.

NEEDS ADMIN	WINDOWS	MAC
No	OS version, patches, firewall profiles and rules, local admins, listening ports	OS version, updates, application firewall, admin group, FileVault status
Yes	BitLocker, Defender settings and exclusions, some process names	Process names behind all ports, pf rules

> The only trace left on the server is the pasted text in that terminal's history. Close the window when you're done.

Exporting the accounts XML

For each file the server hosts:

1. Open the file from the server in FileMaker Pro on your laptop, signed in with a Full Access account.
2. Use Save a Copy as XML with only the accounts and security information selected.
3. Name it after the file, for example `Invoices.xml`, and save it to `audits/<client>/<date>/xml/`.

Plain passwords are never in the export, but it can contain encrypted password hashes, so treat the XML files as sensitive. The parser skips the hashes and deletes the XML once it has been read; only the parsed accounts list stays, in `files.json`, for the report.

> The exact menu options are confirmed against the client's FileMaker Pro version when the file-audit skill is built. The skill prints current instructions every time.

When something goes wrong

PROBLEM	WHAT TO DO
Admin API login fails	Check you can open the Admin Console in a browser from your laptop. If not, it's a network or VPN issue. Re-run `audit login` if the password was mistyped.
Certificate warning on connect	Don't bypass it silently. The agent records it as a finding; continue only with the client's OK.
Clipboard doesn't sync over RDP	Check clipboard redirection is on in your RDP client, or copy the block by hand.
Checksum fails on import	The block was cut off. Copy again from BEGIN to END.
Client won't share a Full Access login	Send them the export instructions the agent prints.
A finding looks wrong	Check the answers recorded in step 1. If the rule itself is wrong, raise it in the repo; don't edit the report by hand.

Close-out checklist

- [ ] Report reviewed end to end, summary written
- [ ] PDF delivered to the client's named contact
- [ ] `audit logout` run; nothing stored in your keychain for this client
- [ ] Client asked to rotate the Admin Console password
- [ ] Engagement folder copied to RCC client storage
- [ ] Local engagement folder deleted after 90 days
- [ ] `git status` clean: nothing from the engagement staged

RCC · FileMaker Security Audit · Consultant guide, draft v0.1. See the sample report in `docs/sample-report.html` for what the client receives.